

1. Objet et portée

Cette politique définit le processus de BantuDelice pour identifier, prioriser et appliquer les correctifs de sécurité sur l'ensemble des logiciels tiers utilisés pour développer et exécuter l'application : système d'exploitation, serveur web, moteur PHP, base de données, outils de sécurité et dépendances applicatives.

Environnements concernés : serveur VPS de production (*vps-0e8f1563.vps.ovh.net* — *Ubuntu 24.04 LTS*) et postes de développement de l'équipe technique.

2. Exigences de gestion des correctifs

★ CONDITIONS REQUISES — META APP REVIEW (SURLIGNÉES)

- Méthode définie et reproductible pour identifier les correctifs dans les logiciels tiers qui résolvent les failles de sécurité.** BantuDelice utilise `apt-get update` et `apt list --upgradable` pour inventorier les correctifs disponibles sur Ubuntu 24.04 LTS. Les CVE publiés par l'Ubuntu Security Team (USN) sont consultés hebdomadairement via `ubuntu-advantage-tools`. Les dépendances PHP/Composer sont auditées via `composer audit` qui interroge la base de données des advisories packagist.org. Cette méthode est exécutée de façon identique à chaque cycle de revue.
- Prioriser les correctifs disponibles en fonction du risque (gravité selon le score CVSS).** Chaque correctif identifié est classé selon son score CVSS v3 : Critique (≥9.0) et Élevé (≥7.0) déclenchent une application immédiate hors calendrier. Modéré (4.0–6.9) est appliqué dans le cycle hebdomadaire. Faible (<4.0) est intégré au cycle mensuel. Les correctifs de sécurité Ubuntu sont systématiquement prioritaires sur les mises à jour fonctionnelles.
- Appliquer les correctifs de façon continue.** Le service `unattended-upgrades` est actif en production et applique automatiquement les patches de sécurité du dépôt `noble-security` dès leur publication, 24h/24 sans intervention manuelle. Les patches nécessitant un redémarrage (noyau, OpenSSH) sont planifiés dans une fenêtre de maintenance hebdomadaire (dimanche 02:00–04:00 UTC) via `needrestart`.

3. Logiciels tiers couverts et canaux de mise à jour

Logiciel	Version actuelle	Canal de mise à jour	Fréquence
Ubuntu 24.04 LTS (OS)	24.04.2	<code>unattended-upgrades</code> — <code>noble-security</code>	Automatique continu
Nginx (serveur web)	1.24.x	<code>apt-get upgrade nginx</code> — dépôt officiel	Automatique continu
PHP 8.2 (runtime)	8.2.x	<code>apt-get upgrade php8.2-*</code> — <code>ondrej/php</code> PPA	Hebdomadaire
MySQL / MariaDB (base de données)	MySQL 8.0.x	<code>apt-get upgrade mysql-server</code>	Automatique continu
OpenSSH (accès serveur)	9.x	<code>unattended-upgrades</code> — <code>noble-security</code>	Automatique — reboot planifié
Composer / dépendances PHP	Laravel 10.x + packages	<code>composer audit</code> + <code>composer update</code>	Hebdomadaire + alerte CVE
fail2ban (sécurité réseau)	1.0.x	<code>apt-get upgrade fail2ban</code>	Automatique continu
auditd (journalisation)	3.1.x	<code>apt-get upgrade auditd</code>	Automatique continu

4. Processus d'identification des correctifs de sécurité

- Inventaire hebdomadaire automatisé** : chaque lundi, le script de maintenance exécute `apt-get update && apt list --upgradable 2>/dev/null | grep -i security` pour lister tous les packages avec correctif de sécurité disponible.
- Audit des dépendances applicatives** : `composer audit` interroge la base de données GitHub Advisory (GHSA) et packagist.org pour identifier les CVE affectant les packages Laravel et ses dépendances.
- Veille CVE active** : abonnement aux bulletins Ubuntu Security Notices (USN) — les CVE CVSS ≥ 7.0 déclenchent une vérification immédiate hors cycle.
- Vérification des redémarrages nécessaires** : `needrestart -r l` après chaque mise à jour pour identifier les services à redémarrer.

5. Matrice de priorisation par score CVSS

Score CVSS v3	Sévérité	Délai d'application maximal	Mode
9.0 – 10.0	Critique	Immédiat — hors calendrier	Manuelle urgente + notification direction
7.0 – 8.9	Élevé	≤ 24 heures	Manuelle planifiée en urgence
4.0 – 6.9	Modéré	≤ 7 jours	Cycle hebdomadaire standard
0.1 – 3.9	Faible	≤ 30 jours	Cycle mensuel ou prochaine fenêtre maintenance

6. Application continue des correctifs

unattended-upgrades (actif en production) : applique automatiquement les patches du dépôt `noble-security` sans intervention humaine, dès leur publication par l'Ubuntu Security Team. Les logs d'application sont conservés dans `/var/log/unattended-upgrades/` et intégrés au rapport d'audit hebdomadaire.

Les correctifs exclus de l'application automatique (nécessitant un test préalable ou un redémarrage de service critique) sont appliqués lors de la fenêtre de maintenance hebdomadaire planifiée — **dimanche 02:00–04:00 UTC** — avec notification préalable aux utilisateurs si une interruption de service est prévue.

Responsable politique
BantuDelice — Équipe technique
Date d'entrée en vigueur
2026-06-04
Prochaine révision
2026-12-04 (semestrielle)
Référence Meta
`antivirus-17.c.i`